

Threat Modeling Bill of Materials

Use Cases and Requirements

OWASP CycloneDX Workgroup	Threat Modeling FWG
Ecma Technical Committee	TC54
Ecma Task Group	N/A
Meeting Invite	Google Calendar Link
GitHub Issue	CycloneDX/specification/issues/462
Models and Data Types	Google Doc
Slack Channel	#workstream-threat-model (invite)
Meeting Recordings	Threat Modeling WG (TM-BOM) playlist

Threat modeling is a set of practices that involves identifying, assessing, and mitigating potential threats, weaknesses, and vulnerabilities within an organization's systems and applications. This process can encompass security, privacy, and safety considerations, ensuring systems are protected against unauthorized access, sensitive information is properly handled, and users are shielded from harm.

CycloneDX will be extended to incorporate threat modeling concepts such as threats, weaknesses, and controls. This proposed enhancement will integrate seamlessly with existing CycloneDX capabilities such as components, services, vulnerabilities, standards, and attestations. By adding these new dimensions, CycloneDX will provide a more comprehensive view of security and privacy, enabling organizations to identify and assess potential threats and weaknesses within their software and systems. The inclusion of controls will offer structured methods for mitigating identified risks. This holistic approach ensures that all aspects of software security, from detailed component information to high-level threat analysis and risk management, are cohesively managed within the CycloneDX framework, promoting a more resilient and secure software supply chain.

Interoperability has been a significant challenge for threat modeling, as traditional tools have often relied on proprietary formats, hindering seamless data exchange between different platforms. In the short term, some threat modeling tools have begun supporting the [Open Threat Modeling](#) (OTM) format, an open-source project by IriusRisk, to address this issue. However, OTM has limitations that restrict its efficacy for moderate to advanced use cases, creating gaps in interoperability. CycloneDX TM-BOM aims to bridge this gap by supporting a comprehensive range of threat modeling scenarios, facilitating robust interoperability between all threat modeling platforms. By adopting TM-BOM, organizations can ensure that their threat modeling

data is consistently and effectively shared and utilized across various tools, enhancing collaboration and improving the overall efficacy of their security and privacy strategies.

Use Cases

U1: Enhancing Interoperability in Threat Modeling

Scenario

A financial institution, AcmeFinance, uses a diverse set of threat modeling tools across its various departments and subsidiaries. Each tool has its proprietary format for representing threats, weaknesses, and controls, leading to challenges in maintaining a cohesive and interoperable security strategy.

Current Challenge

- **Lack of Standardization:** Different departments using different threat modeling tools results in disparate data formats, making it difficult to integrate and analyze threat data comprehensively.
- **Inefficient Collaboration:** Security teams across the organization struggle to collaborate effectively due to incompatible threat modeling formats, slowing down the identification and mitigation of security risks.
- **Data Silos:** Critical threat information is trapped within individual tools, creating silos that prevent the organization from having a unified view of its security posture.

Solution with CycloneDX TM-BOM

- **Adoption of TM-BOM:** AcmeFinance decides to adopt CycloneDX TM-BOM as a standardized format for threat modeling data across all its tools and platforms.
- **Data Conversion:** Existing threat modeling data from proprietary formats are converted into the TM-BOM format. This includes detailed information on threats, weaknesses, controls, components, services, vulnerabilities, standards, and attestations.
- **Unified Data Repository:** A central repository is established where TM-BOM files from various departments are stored and managed. This repository enables easy access and integration of threat modeling data across the organization.

Benefits

- **Improved Interoperability:** By standardizing on TM-BOM, AcmeFinance ensures that all threat modeling tools can exchange data seamlessly, regardless of their original proprietary formats.

- **Enhanced Collaboration:** Security teams across different departments can now collaborate more effectively, sharing and analyzing threat data in a consistent format. This leads to quicker identification and resolution of potential security issues.
- **Comprehensive Security View:** With all threat modeling data unified in TM-BOM format, AcmeFinance gains a holistic view of its security posture. This allows for better-informed decision-making and more strategic allocation of resources to address the most critical threats.
- **Future-Proofing:** As TM-BOM supports a wide range of threat modeling use cases, AcmeFinance is well-positioned to integrate future tools and technologies into its security ecosystem without worrying about interoperability issues.

U2: Streamlining Vendor Risk Management

Scenario

A technology company, AcmeTech, works with numerous third-party vendors who provide software components and services. Each vendor uses different threat modeling tools and formats.

Current Challenge

- **Inconsistent Data:** Vendors submit threat modeling data in various formats, creating inconsistency and making it difficult for AcmeTech to assess risks accurately.
- **Manual Integration:** The security team spends significant time manually integrating and analyzing threat data from different vendors.

Solution with CycloneDX TM-BOM

- **Standardized Submissions:** Vendors are required to submit threat modeling data in CycloneDX TM-BOM format.
- **Automated Analysis:** AcmeTech's security tools automatically ingest and analyze TM-BOM files, providing a unified view of risks associated with third-party components and services.

Benefits

- **Consistency:** Uniform data format across all vendors.
- **Efficiency:** Reduced time and effort in data integration and analysis.
- **Comprehensive Risk Assessment:** Improved ability to identify and mitigate third-party risks.

U3: Enhancing Mergers and Acquisitions Security Due Diligence

Scenario

A large corporation, AcmeGlobal, is in the process of acquiring a smaller software company, AcmeLocal. Assessing the security posture of AcmeLocal's products and services is a critical part of the due diligence process.

Current Challenge

- **Disparate Systems:** AcmeLocal's threat modeling data is in proprietary formats not easily compatible with AcmeGlobal's systems.
- **Time Constraints:** Limited time to conduct thorough security assessments during the M&A process.

Solution with CycloneDX TM-BOM

- **Unified Format:** AcmeLocal converts its threat modeling data to CycloneDX TM-BOM format.
- **Streamlined Evaluation:** AcmeGlobal's security team quickly ingests and evaluates the TM-BOM data using their existing tools.

Benefits

- **Accelerated Due Diligence:** Faster and more thorough security assessments.
- **Reduced Risk:** Comprehensive understanding of security risks in the acquired company.
- **Seamless Integration:** Easier integration of AcmeLocal's systems into AcmeGlobal's security framework post-acquisition.

U4: Facilitate Regulatory Compliance

Scenario

A healthcare provider, AcmeHealth, must comply with stringent regulatory requirements for data protection and security.

Current Challenge

- **Complex Compliance:** Keeping up with diverse regulatory requirements and ensuring all security measures are documented and traceable.
- **Audit Preparation:** Preparing for regular security audits is time-consuming and complex.

Solution with CycloneDX TM-BOM

- **Compliance Mapping:** Threat modeling data in TM-BOM format includes mappings to relevant regulatory standards and controls.
- **Audit Trails:** TM-BOM provides detailed and standardized documentation of threats, weaknesses, and controls, facilitating audit preparation.

Benefits

- **Simplified Compliance:** Easier to demonstrate compliance with regulatory standards.
- **Efficient Audits:** Streamlined preparation and execution of security audits.
- **Traceability:** Clear and consistent documentation of security measures.

U5: Support Secure Software Development Lifecycle (S-SDLC)

Scenario

A software development firm, AcmeSoftware, aims to integrate threat modeling into its Secure Software Development Lifecycle (S-SDLC).

Current Challenge

- **Fragmented Data:** Security and development teams use different tools, leading to fragmented threat modeling data.
- **Delayed Mitigation:** Identifying and mitigating security risks late in the development process.

Solution with CycloneDX TM-BOM

- **Integrated Workflow:** TM-BOM format is used to document threats, weaknesses, and controls from the design phase through to deployment.
- **Early Detection:** Security tools automatically analyze TM-BOM data during each SDLC phase, identifying risks early.

Benefits

- **Seamless Integration:** Unified threat modeling data across all SDLC phases.
- **Proactive Security:** Early identification and mitigation of security risks.
- **Enhanced Collaboration:** Improved communication between security and development teams.

Requirements

R1: Methodology agnostic

CycloneDX should not prescribe any threat modeling methodology, rather, it should be agnostic and support (at a minimum):

- STRIDE
- STRIDE-LM
- PASTA
- LINDDUN

R2: Schema Extensions

Extend the CycloneDX schema to include new elements for:

- Threats
- Weaknesses
- Controls
- Regulatory mappings
- Diagrams
 - Diagram perspective (infrastructure, software architecture, etc)
 - Data flow diagram (DFD)
 - Attack tree
- Multiple diagrams per threat model

R3: Backward Compatible

Ensure backward compatibility with CycloneDX v1.6, allowing smooth transition and integration of new features.

R4: Documentation and Guidelines

Update the CycloneDX documentation to include detailed guidelines for using the new TM-BOM features and extensions.

What are we working on

Asset threat modeling - system components, processes, etc

Process threat modeling - supply chain, deployments, updates, etc

Diagrams - attack trees, DFDs, etc

Use cases / abuse cases (optional)

THIS DOCUMENT IS CURRENTLY IN DRAFT AND ACTIVELY BEING WORKED ON

Requirements (optional - functional and non-functional) (maybe get inspired by <https://www.omg.org/spec/ReqIF/1.2/PDF>)

Existing component types: https://cyclonedx.org/docs/1.6/json/#components_items_type

Plus CycloneDX supports services

If threat modeling assets, then those assets are required

Diagrams are common to assets and process threat modeling, but are optional

Must support CIA + privacy + safety. Optionally make it extensible. The prioritization of each should be supported so that C and I can be defined as less important than A for example. Use “profiles” (similar to scope) so that there can be different perspectives for prioritization.

Threats identified based on missing requirements and have a link to those requirements

Entry /exit points will need to be supported on components in addition to services

Look into <https://github.com/CycloneDX/specification/issues/321> for external dependencies

Learning towards not supporting “trust levels” as defined at https://owasp.org/www-community/Threat_Modeling_Process.

Threat categorization: Need to support STRIDE, STRIDE-LM, LINNDUN, CWE but not be confined to these. Schema must be extensible so that others can define their own categorization. CWE is one way to categorize threats and theoretically, a STRIDE classification could be derived from CWE.

Mapping: MITRE ATT&CK, CAPEC,

Non-asset things we need to capture:

- Trust boundaries, physical and logical
- what is the system we modeling and what are the dependencies of that system.
- Scope definitions - Need to add “profiles” for each perspective where things can be marked as in-scope and out-of-scope per profile. For example, an “infrastructure” profile.
- Configuration is part of the details of an asset. And it would be good to include references to where the source code lives, etc. Possibly, attributes on an object. This is a parking lot item and not MVP.

THIS DOCUMENT IS CURRENTLY IN DRAFT AND ACTIVELY BEING WORKED ON

Bom-refs on every object, every process, every dataflow, etc